SIZMA TESTİ RAPORU

Rapor Tarihi	02/10/2026
Hazırlayan	Ömer Faruk Baysal
Test Hedefi	PortSwigger Web Academy Lab

1. SSRF Zafiyetleri

Bu raporda, PortSwigger Web Security Academy'de yer alan SSRF (Server-Side Request Forgery) zafiyetleri farklı 4 durum olarak ele alınmıştır.

2. Yönetici Özeti

İlgili sitenin stok kontrol fonksiyonunun post metodunda yer alan stockApi parametresinde herhangi bir doğrulama yapılmadığı tespit edilmiş olup saldırganın bu parametre üzerinden sunucuyu iç ağ kaynaklarına (localhost ve özel ip) istek atmaya zorlayabildiği tespit edilmiştir. Bu erişim ile birlikte admin seviyesinde işlemlerin gerçekleştirilebildiği kanıtlanmıştır. Ayrıca uygulanan kara liste filtrelerinin ise çeşitli kodlama ve IP gösterim yöntemleriyle aşılabildiği tespit edilmiştir. Kara liste filtrelerinin de işe yaramadığı durumlarda ise yönlendirme açığı ile doğrulama eksikliğinin birleştirilip tek bir saldırı halinde zafiyetin sömürülebileceği de kanıtlanmıştır.

3. Zafiyet Açıklaması

Durum 1 ve 2: Basic SSRF against the local server & against another back-end system

Hedef sitede yer alan stok kontrol fonksiyonunun post metodunda yer alan stockApi parametresinde herhangi bir doğrulama yapılmadığı tespit edilmektedir. Saldırganın bu parametre üzerinden sunucuyu iç ağ kaynaklarına (localhost ve özel ip) istek atmaya zorlayabildiği tespit edilmiştir. Bu da SSRF zafiyetini kanıtlamaktadır. Bu erişim ile birlikte admin seviyesinde işlemlerin gerçekleştirilebildiği PoC adımlarıyla kanıtlanmıştır.

Durum 3: SSRF with blacklist-based input filter

İlk iki duruma ek doğrulama yapıldığı gözlemlemlense de (blacklist/kara liste yöntemiyle) bu doğrulamanın çeşitli encoding yöntemleriyle aşılabildiği PoC adımlarıyla kanıtlanmıştır.

Durum 4: Bypassing SSRF filters via open redirection

İlk iki duruma ek doğrulama yapıldığı gözlemlemlenmiş, durum üçe ek bu sefer kara liste/blacklist'in aşılamadığı tespit edilmiştir. Bunun sonucunda sitede yer alan başka özellikler test edilmiş olup /product/stock kısmında yönlendirmeye (redirection) rastlanmıştır. Bu yönlendirme kullanılarak POST metodundaki stockApi parametresinde bu yönlendirmenin istenen admin arayüzüne erişiminin sağlanmasında kullanılabileceği PoC adımlarıyla kanıtlanmıştır.

4. Risk Seviyesi

Risk Seviyesi	Kritik
CVSS v3.1 Skoru	9.4
CVSS v3.1 Vektörü	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:L
CWE	CWE-918: Server-Side Request Forgery (SSRF)

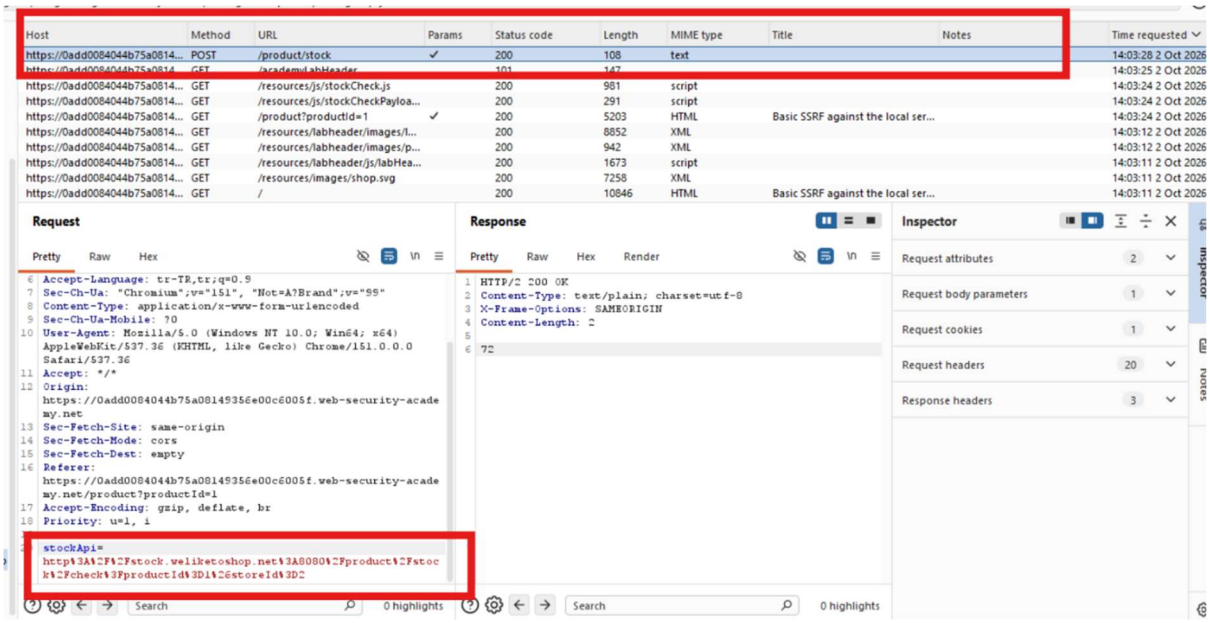
5. Etki

Doğrulama olmayan metodda yer alan parametre üzerinden sunucunun iç ağ kaynaklarına istek atılabilmesi ve bu sayede de admin seviyesinde işlemlerin gerçekleştirilebilmesi sistemin bütünlüğünü bozmaya yol açacak derecede ciddi bir etkinin oluşmasını göstermektedir.

6. Proof Of Concept

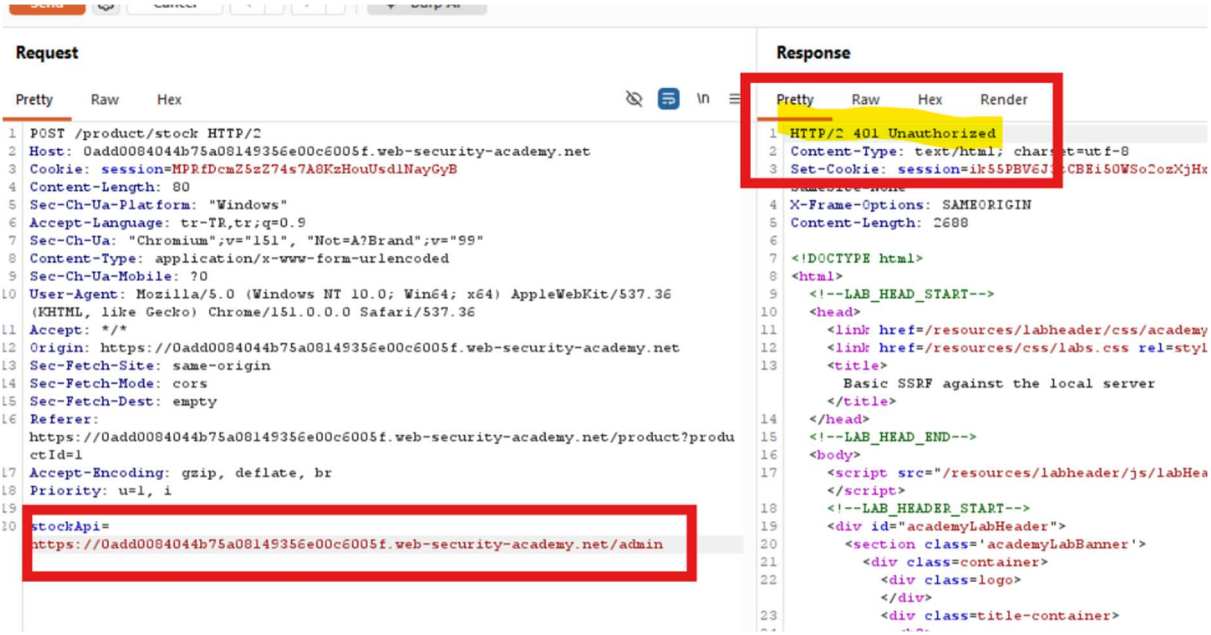
Durum 1: Basic SSRF against the local server

Test sitesinde yer alan ürünler sayfasındaki ürün incelendiğinde buradaki stok kontrolü fonksiyonunun post metodunda yer alan stockApi parametresinin, sunucu tarafında herhangi bir doğrulamadan geçirilmeden harici bir http isteğinde kullanıldığı tespit edilmiştir.



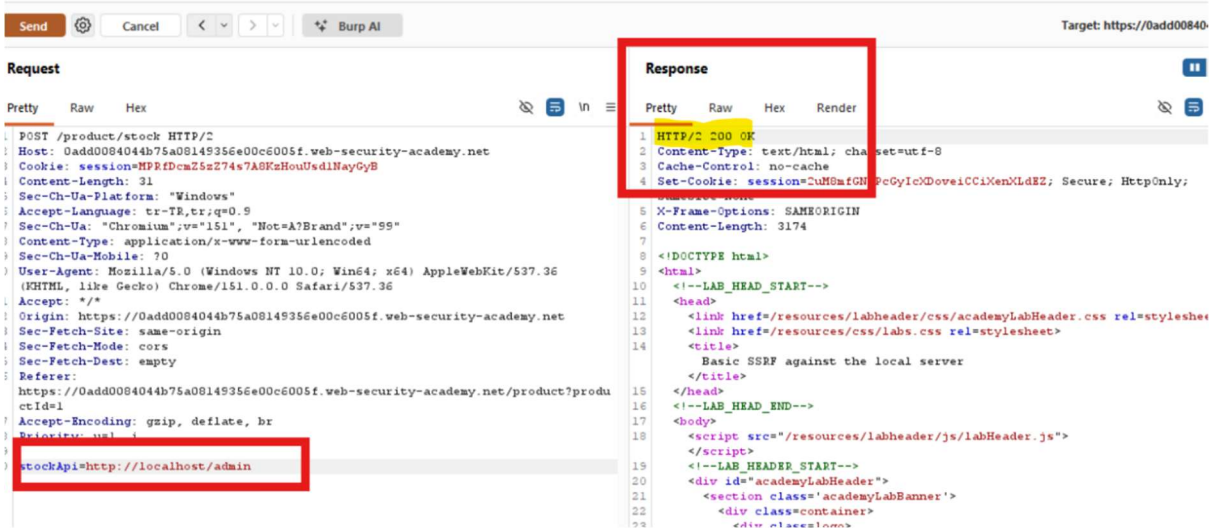
Şekil 1: stockApi parametresinde http isteği kullanılıyor, hiçbir doğrulama olmadan

İlk olarak dış ağı kullanarak admin sayfasına erişim test edilmiştir ancak yetkisiz erişim hata kodu ile karşılaşılmıştır:



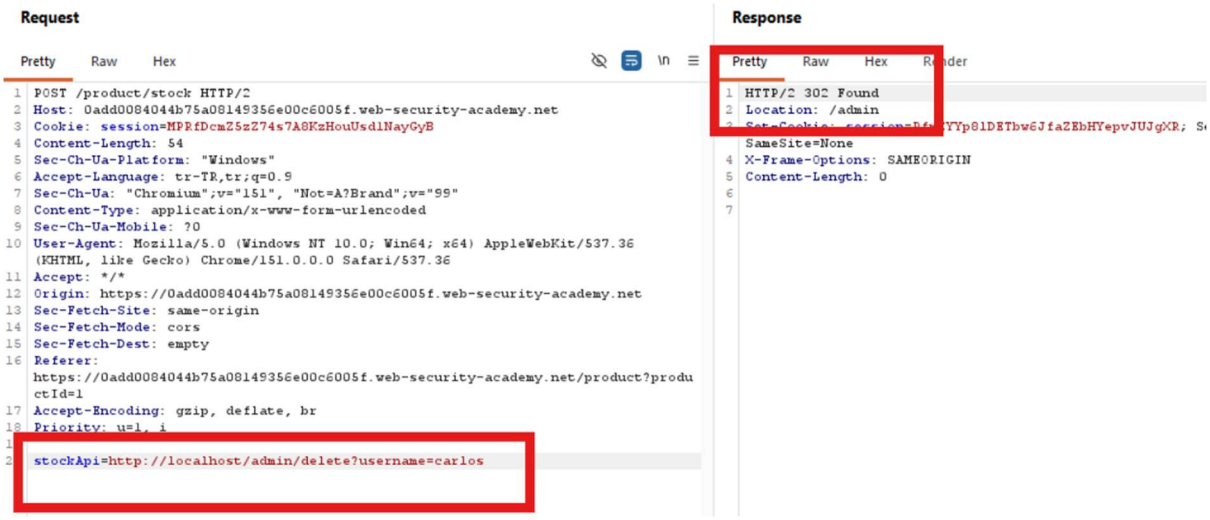
Şekil 2: 401 Unauthorized

Bir sonraki denemede iç ağdan admin sayfasına erişim denenmiştir ve başarılı olunmuştur. Bu da sitede SSRF açığını kanıtlamaktadır:



Şekil 3: İç ağ ile admin sayfasına erişim (localhost)

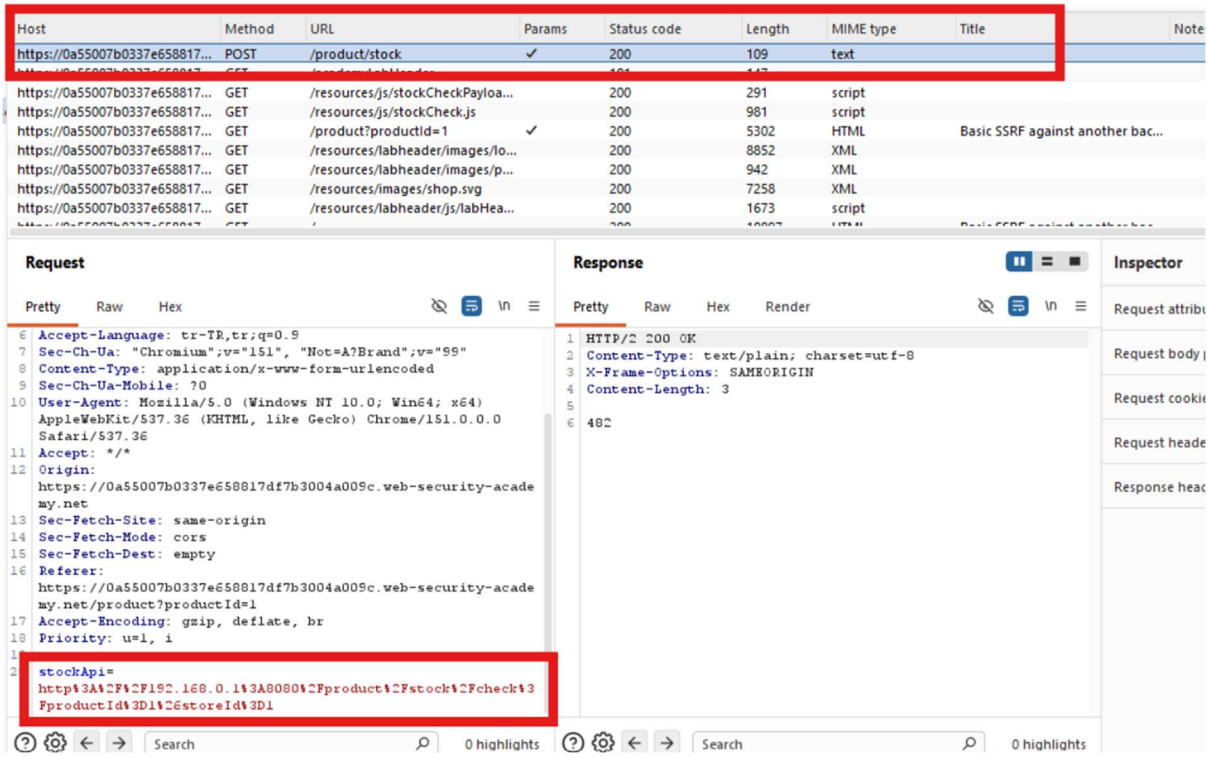
Test hedefinde silinmesi istenen carlos kullanıcısı, bu açıktan yararlanılarak başarıyla silinmiştir:



Şekil 4: /admin/delete?username=carlos

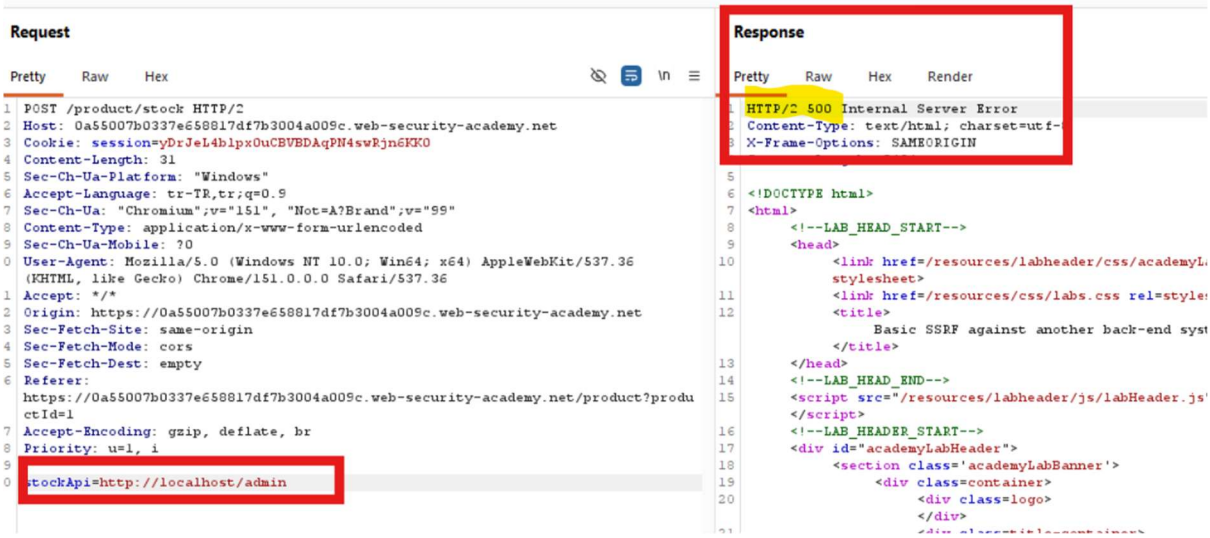
Durum 2: Basic SSRF against another back-end system

Test sitesinde yer alan ürünler sayfasındaki ürün incelendiğinde buradaki stok kontrolü fonksiyonunun post metodunda yer alan stockApi parametresinin, sunucu tarafında herhangi bir doğrulamadan geçirilmeden harici bir http isteğinde kullanıldığı tespit edilmiştir:



Şekil 5: Herhangi bir doğrulama yok

Bir sonraki aşama olarak iç ağdan admin hesabına erişim test edilmiştir ancak başarısız olunmuştur:

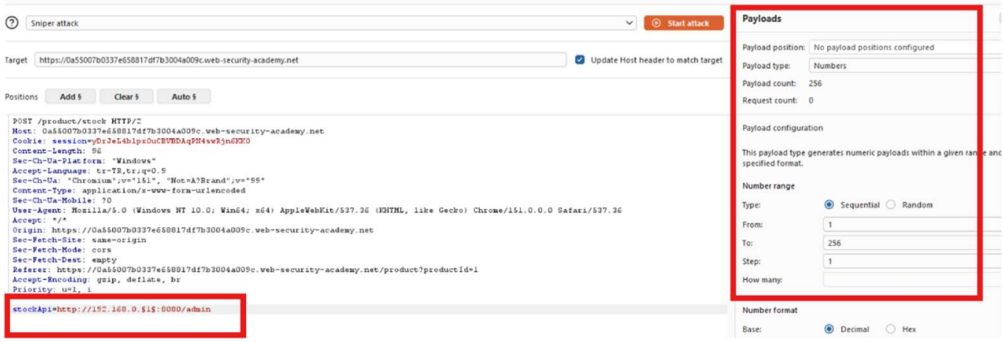


Parametre dikkali incelendiğinde özel bir ip dikkat çekmektedir:

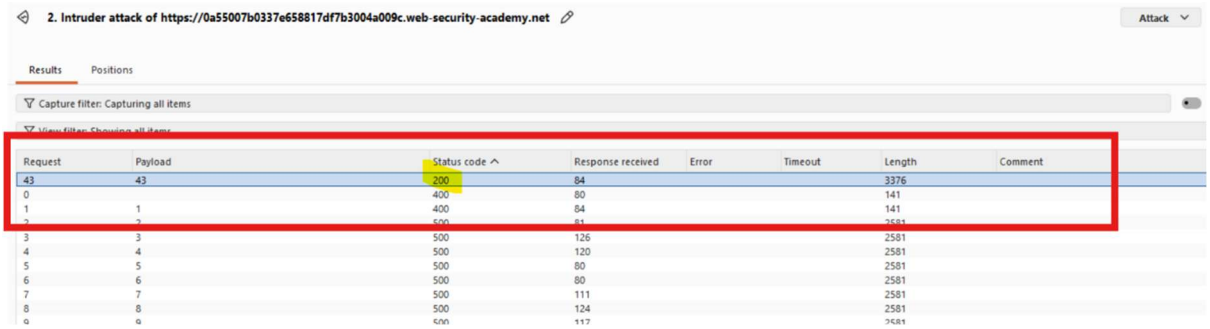


Görülen 192.168.0.1 ağ adresi internete kapalı, yalnızca yerel ağlarda kullanılan bir adrestir. Yani burada yer alan 192.168.0.X adresiyle backend sunucuları arasında iletişim yapılmaktadır.

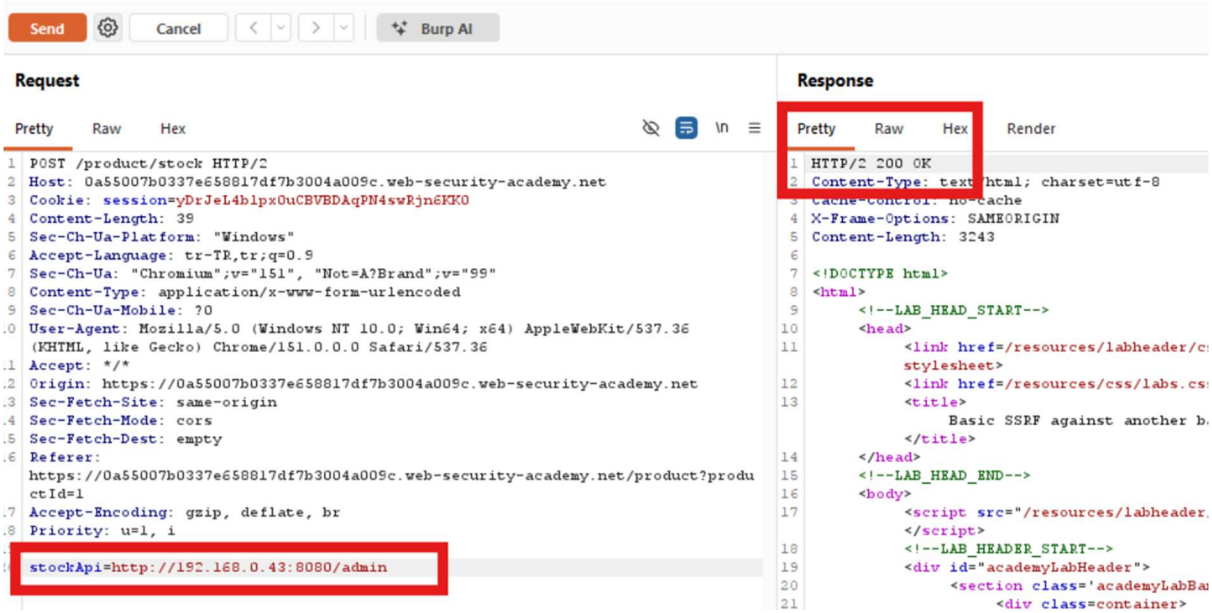
Ip adresi ağ adresi olarak C sınıfında olduğu için (192.168.0.X) X yerine 0-255 arası tüm sayıların gelme ihtimali göz önüne alınarak ilgili post metodu Burp Intruder'a gönderilip Sniper Attack yapılarak doğru adresi bulmak hedeflenmiştir.



Yapılan saldırıcı sonucu “43”. Adreste 200 OK kodu dönmüştür. Yani 192.168.0.43 aradığımız adrestir.

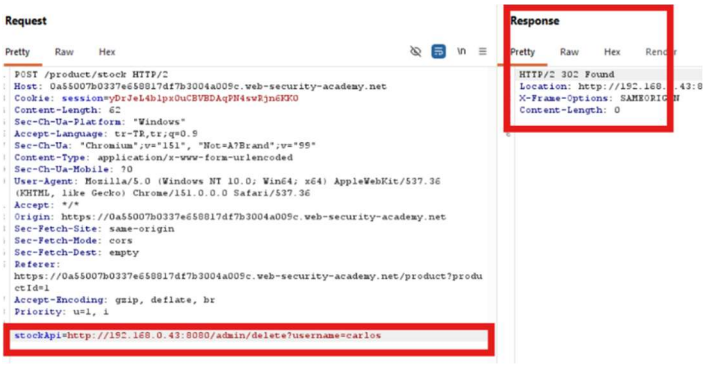


Bu sonuca göre Burp Repeater’da istek tekrar ele alınır ve parametre düzenlenip istek yollanır.



Yollanan isteğin cevabında admin sayfasına başarılı erişim gözlemlenir. İç ağdan göndertilen istek başarıyla admin sayfasına ulaşması SSRF açğını da kanıtlamaktadır.

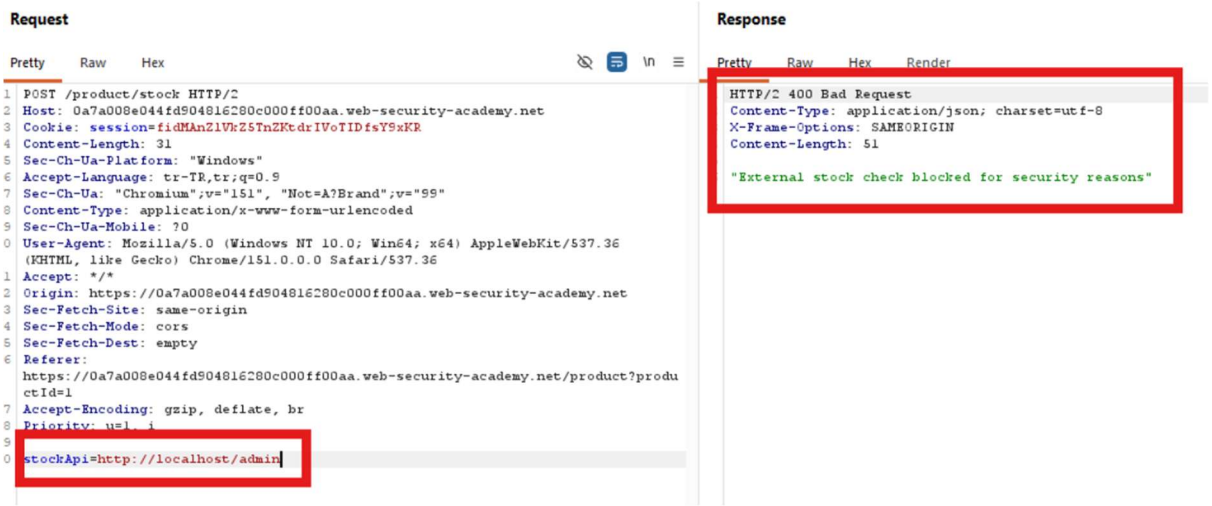
Test için istenen carlos kullanıcsının silinmesi de bu açık sayesinde yapılabilmektedir:



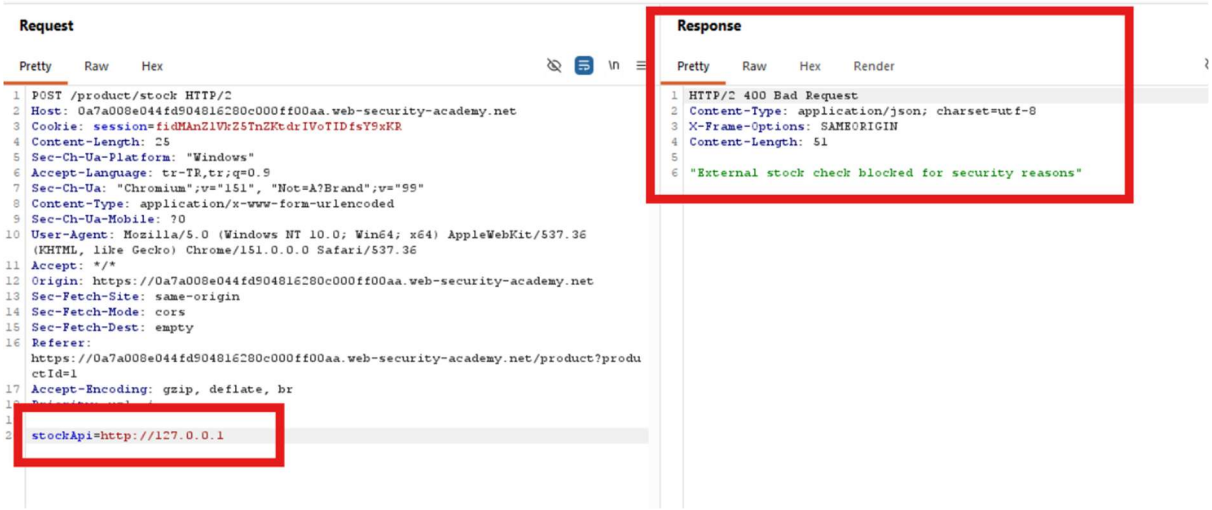
Durum 3: SSRF with blacklist-based input filter

İlk 2 durumdakiyle aynı şekilde olmak üzere ürünler sayfasındaki ürün incelendiğinde buradaki stok kontrolü fonksiyonunun post metodunda yer alan stockApi parametresinin, sunucu tarafında herhangi bir doğrulamadan geçirilmeden harici bir http isteğinde kullanıldığı tespit edilmiştir. Fakat burada doğrulama olmamasına karşın blacklist (kara liste) yöntemiyle belirli kelimelerin engellendiği gözlemlenmiştir.

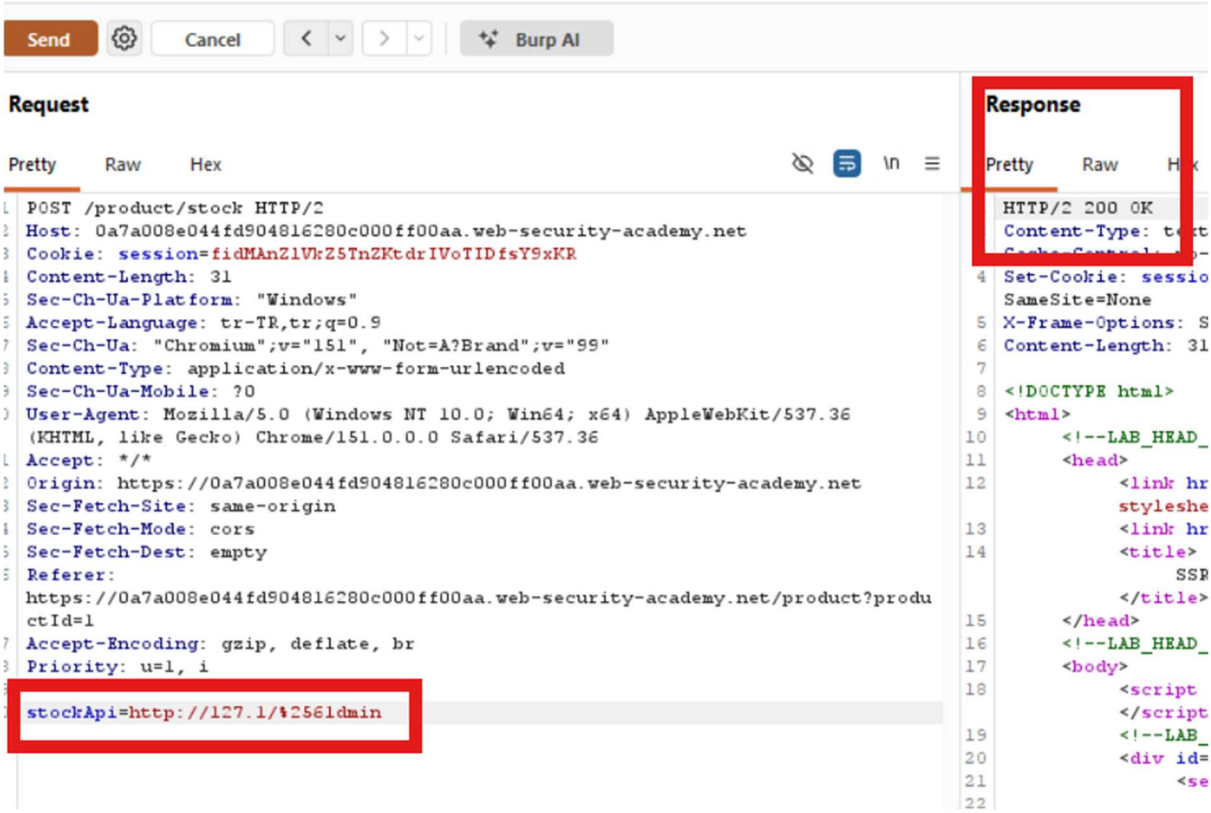
Yönetim paneline erişim sağlamak amacıyla parametreye http://localhost/admin değeri atanarak istek gönderilmiştir. Sunucu bağlantıyı doğrudan reddetmek yerine 400 Bad Request durum kodu ile birlikte External stock check blocked for security reasons yanıtını dönmüştür. Bu durum; sunucu üzerinde dahili IP adreslerine ve yerel hedeflere yönelik statik anahtar kelime eşleşmesine dayalı bir kara liste filtresinin devrede olduğunu doğrulamıştır.



Sunucunun yerel yönetim servislerine erişim için 127.0.0.1 ip adresi stockApi parametresinde denenmiştir:

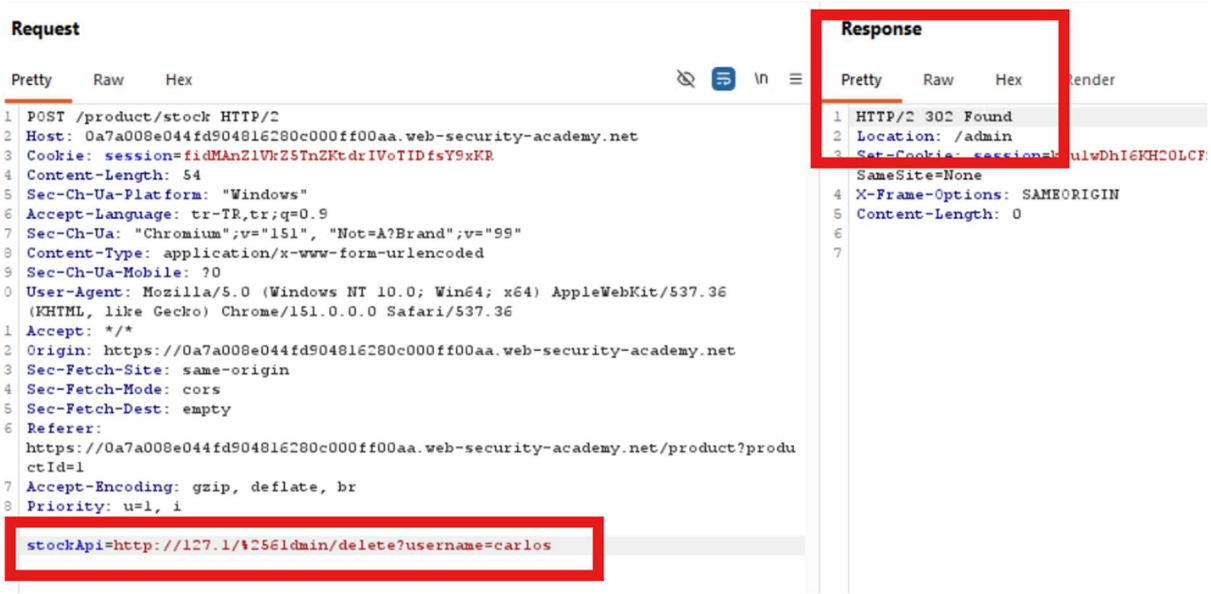


Aynı şekilde burada da engellemeyle karşılanmıştır. Bunu aşmak için double encoding ve formatlama yöntemleriyle istek tekrar gönderilmiştir:



Burada admin kelimesinde double encoding ile (a harfinin ASCII karşılığı -> 61 ve yüzde işaretinin encodingi -> %25) ile birlikte “%2561dmin” encodingi uygulanmıştır.

127.0.0.1 ip adresi yerine de alternatif 127.1 ip adresi kullanılmıştır. Bunun sonucunda yanıt olarak 200 OK yanıtı başarıyla alınmıştır.

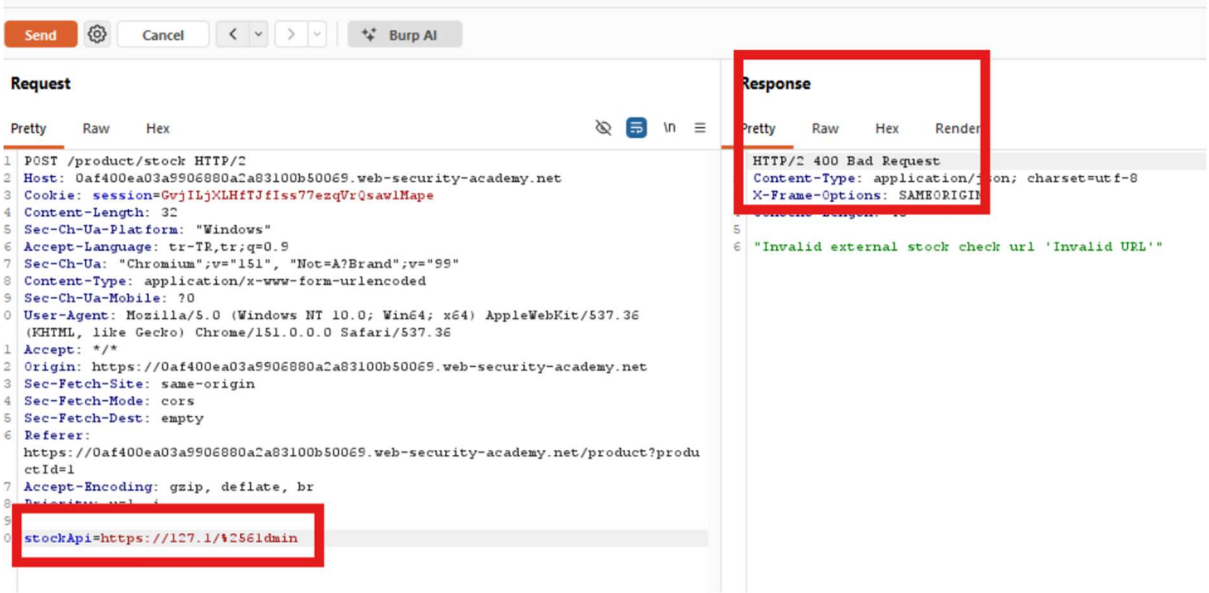


Test için istenen carlos hesabının silinmesiyle ilgili istek, bu parametreye eklenerek test başarıyla gerçekleştirilmiştir.

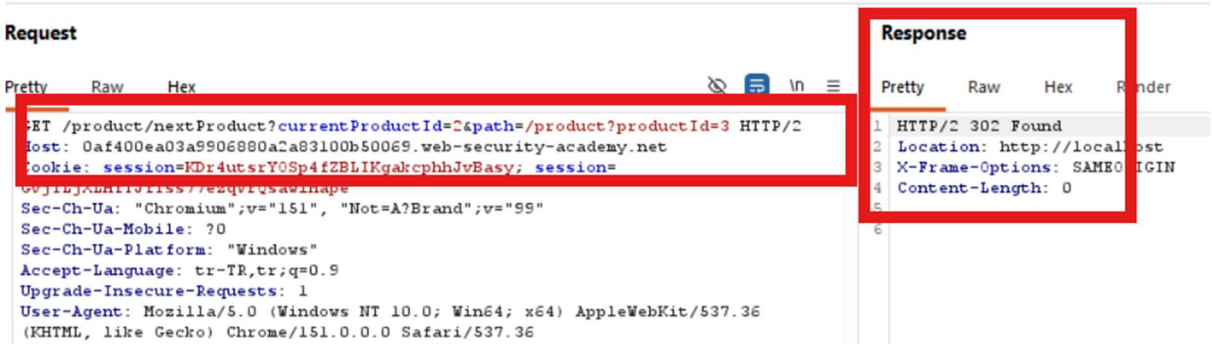
Durum 4: Bypassing SSRF filters via open redirection

İlk 2 durumdakiyle aynı şekilde olmak üzere ürünler sayfasındaki ürün incelendiğinde buradaki stok kontrolü fonksiyonunun post metodunda yer alan stockApi parametresinin, sunucu tarafında herhangi bir doğrulamadan geçirilmeden harici bir http isteğinde kullanıldığı tespit edilmiştir. Ayrıca durum üçteki gibi burada doğrulama olmamasına karşın blacklist (kara liste) yöntemiyle belirli kelimelerin engellendiği gözlemlenmiştir.

Durum üçde kullanılan encoding yöntemlerinin de işe yaramadığı ayrıca kanıtlanmıştır:



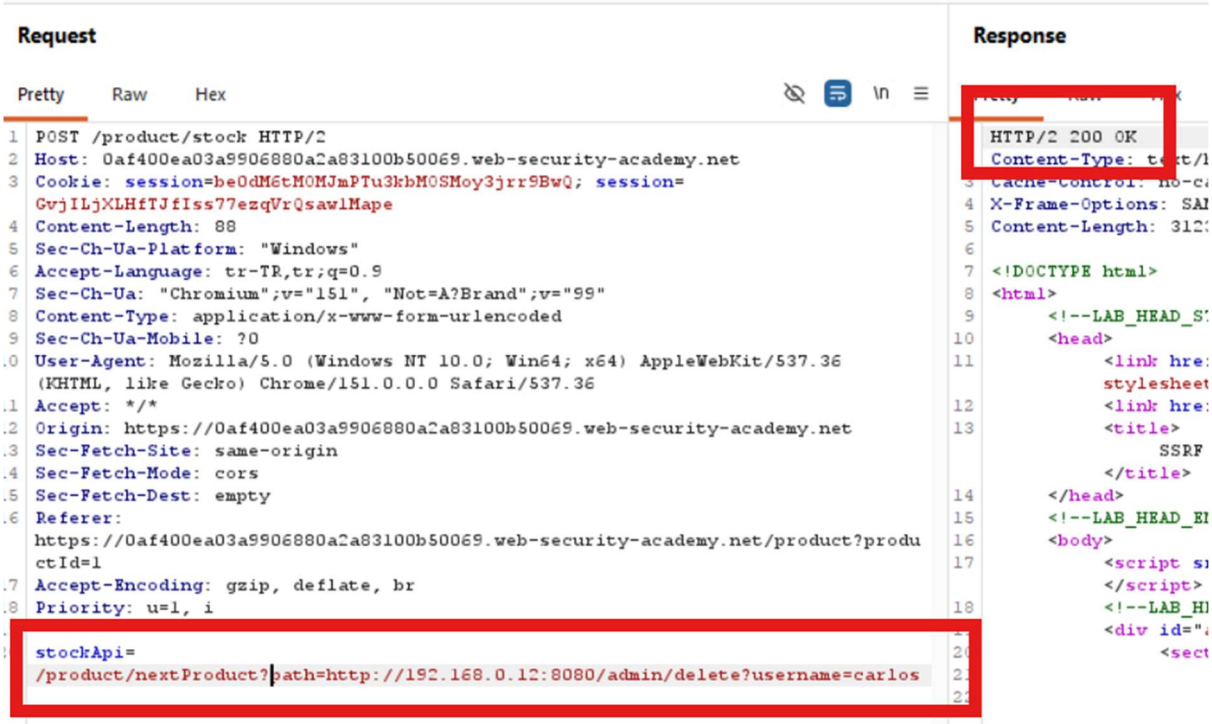
Sayfada yer alan “Next product” butonuna tıklanıp istek incelendiğin /product/stock kısmında yönlendirmeye (redirection) rastlanmıştır.



Buradaki yönlendirmenin başka bir siteye de yönlendirp yönlendirmediği test edilmiş ve yönlendirdiği kanıtlanmıştır:



Buradaki yönlendirme, ilk baştaki stokApi parametresine eklenerek tekrar test yapılmıştır. Bu test başarıyla gerçekleştirilmiştir. Test hedefi olarak istenen



http://192.168.0.12:8080/admin arayüzüne erişim sağlanarak buradan carlos kullanıcısının silinebileceği kanıtlanmıştır.

7. Çözüm Önerisi

İç ağa erişimin kontrol altına alınması ve isteklerin gönderilirkene doğrulamadan geçirilmesi gereklidir:

Beyaz Liste (Whitelist) Doğrulaması: Sunucunun istek göndereceği IP ve alan adları sıkı bir beyaz liste kontrolünden geçirilmeli, yalnızca izin verilen harici stok API adreslerine bağlantı kurulmalıdır.

Yerel/Özel IP Bloklarının Engellenmesi: Kullanıcıdan alınan URL'lerin loopback (127.0.0.1, localhost) ve RFC 1918 özel IP bloklarına (10.0.0.0/8, 172.16.0.0/12, 192.168.0.0/16) çözümlenmesi uygulama ve ağ katmanında engellenmelidir.

Ağ Segmentasyonu ve Yetkilendirme: İç yönetim servisleri yalnızca istek kaynağının localhost olmasına güvenmemeli; yerel ağdan gelen isteklerde de güçlü kimlik doğrulama mekanizmaları zorunlu kılınmalıdır.

Açık Yönlendirme (Open Redirect) Zafiyetlerinin Giderilmesi: Uygulama içindeki yönlendirme işlevleri (ör. "Next product"), yönlendirme hedefini kullanıcı girdisinden almamalı; hedef bir beyaz listeye karşı doğrulanmalıdır. Açık yönlendirme, SSRF filtrelerini atlatmak için bir "gadget" olarak kullanılabildiğinden kapatılması kritiktir.

Yönlendirmelerin Takip Edilmemesi / Yeniden Doğrulanması: İstekleri gerçekleştiren sunucu bileşeni, yanıtlardaki yönlendirmeleri (3xx / Location başlığı) otomatik takip etmemeli; takip ediyorsa her yönlendirme hedefi, ilk istekteki beyaz liste/filtre kontrollerinden yeniden geçirilmelidir. Aksi halde filtreden geçen bir istek, yönlendirme yoluyla yasak bir iç adrese ulaşabilir.

8. Sonuç

Yapılan testler sonucunda doğrulama olmayan parametre üzerinden sunucunun iç ağ kaynaklarına istek atılabilmesi ve yetersiz kara liste filtreleri üzerinden sunucuda admin seviyesinde işlemlerin gerçekleştirilebildiği kanıtlanmıştır. Ayrıca, kara liste filtresinin güçlendirildiği durumda dahi, uygulamadaki bir açık yönlendirme (open redirect) zafiyeti bir atlatma aracı olarak kullanılarak filtrenin aşılabildiği ve admin arayüzüne erişilebildiği gösterilmiştir. Sonuç olarak SSRF, yalnızca girdi filtreleriyle değil; yönlendirmelerin doğrulanması ve ağ seviyesinde kısıtlamalarla birlikte, savunma derinliği yaklaşımıyla ele alınmalıdır.